SKENARIO 10 | IoT Protocol Guardian

Pengamanan backend SmartCow

SmartCow memantau suhu dan kelembapan kandang untuk mengatur penyemprotan air.

Fokus uji: akses tanpa izin dan pengulangan pesan kendali pada replika laboratorium.

Sensor kandang
6 DS18B20 + 4 DHT22

↓

Dua ESP32
Pengumpulan data suhu dan kelembapan

↓

Firebase
Penyimpanan data dan autentikasi

↓

Dashboard dan kendali
Pemantauan serta pengaturan sprinkler

Cakupan uji hanya lab terisolasi; tidak mengakses Firebase produksi atau aktuator fisik.

Thevan Erlangga
J0404241073 | Lead Team

Muhamad Akhdan Ramadhan
J0404241102 | Red Team

Fachri Abyasa Tarid
J0404241136 | Blue Team

Sumber: deklarasi teknologi SmartCow

Sistem asli dan replika laboratorium

Fungsi backend ditiru; teknologi penyimpanannya berbeda.

Komponen	Sistem asli	Replika lab
OS backend	Layanan terkelola Firebase	Arch Linux pada Target Node
Penyimpanan	Firebase Realtime Database	JSON lokal dan API Python
Komunikasi	HTTPS REST; ESP-NOW antar-ESP32	HTTP REST bertoken; jaringan TCP/IP virtual
Dashboard	Web pada Firebase Hosting	Nginx :80; proxy API ke 127.0.0.1:9000
MQTT	Opsi pengembangan	Broker Python :1883; jalur uji tambahan
Sensor / aktuator	Dua ESP32 dan SSR/solenoid	Simulator data dan status kendali; tanpa 220 V

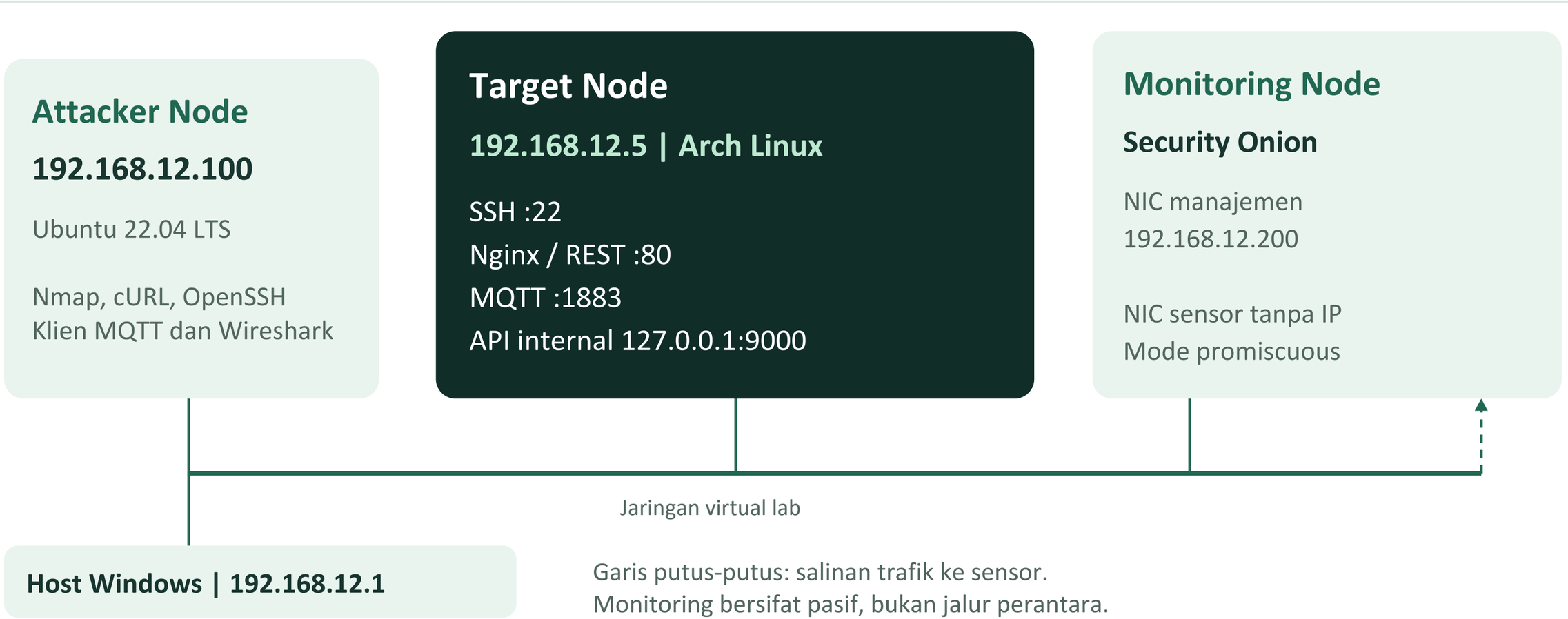
Firebase Emulator tidak tersedia di lab tanpa internet. Python/JSON bukan replika Firebase yang identik.

ESP-NOW dan perangkat fisik tidak direplikasi. HTTP/MQTT lab belum menggunakan TLS.

Sumber: deklarasi teknologi dan batasan replika

Topologi dan pengalamatan jaringan

VirtualBox Host-Only | 192.168.12.0/24 | Data sintetis



Sumber: rencana IP dan topologi lab

Akses dan layanan pada Target Node

Penerapan enam kontrol akses dan layanan pada Target Node.

A | Akses dan autentikasi

A1 Login root dinonaktifkan

PermitRootLogin no; hanya sec_admin

A2 Login SSH menggunakan kunci

Kunci Ed25519; autentikasi sandi dimatikan

A3 Percobaan koneksi dibatasi

MaxStartups 3:50:10; hashlimit untuk attacker

B | Layanan dan permukaan serangan

B1 Firewall persisten

INPUT DROP; layanan lab TCP 22, 80, 1883

B2 API dibatasi ke loopback

Listener API hanya pada 127.0.0.1:9000

B3 Versi Nginx disembunyikan

server_tokens off; nama nginx tetap terlihat

Bukti B2 sebelum: 0.0.0.0:9000

```
LISTEN          0               5                       0.0.0.0:9000
```

Bukti B2 sesudah: 127.0.0.1:9000

```
LISTEN 0      5          127.0.0.1:9000      0.0.0.0:*    users:(("python3",pid=1479,fd=3))
```

Port 9000 sudah filtered pada scan awal. Bukti di atas menunjukkan perubahan alamat listener.

Sumber: checklist A/B dan tangkapan layar listener

Pengamanan data dan aplikasi

C1 dan C3 masih berstatus sebagian; bukti lanjutan diperlukan.

ID	Kontrol	Hasil pengujian	Status
C1	**Validasi input dan ACL MQTT**	Input di luar rentang dan token tidak valid ditolak. ACL dengan akun sensor valid belum terverifikasi.	Sebagian
C2	**Perlindungan kredensial**	Berkas kredensial berizin 600. Token lama ditolak; token baru diterima.	Selesai
C3	**Log aktivitas dan pemulihan**	Token masih terlihat pada log akses. Uji pencadangan dan pemulihan belum berhasil.	Sebagian

Baseline normal: telemetri setiap 2 detik

```
Oct 20 02:36:31 SRV-IOT-KEL12-B python3[1486]: telemetry -> 200
Oct 20 02:36:33 SRV-IOT-KEL12-B python3[1486]: telemetry -> 200
Oct 20 02:36:35 SRV-IOT-KEL12-B python3[1486]: telemetry -> 200
Oct 20 02:36:37 SRV-IOT-KEL12-B python3[1486]: telemetry -> 200
Oct 20 02:36:39 SRV-IOT-KEL12-B python3[1486]: telemetry -> 200
Oct 20 02:36:41 SRV-IOT-KEL12-B python3[1486]: telemetry -> 200
```

Uji input: kelembapan di luar rentang

```
=== telemetry palsu: kelembapan 150 (di luar rentang) ===
{
  "detail": "h1 di luar rentang 0.0..100.0",
  "error": "invalid payload"
}
```

Baseline ini menunjukkan pemrosesan lokal, bukan pemantauan trafik pada NIC sensor.

Sumber: bukti C1/C2/C3 dan simulator telemetri

Hasil pemantauan Security Onion

Pemantauan pasif terhadap trafik antar-node laboratorium.

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	12	seconion-...	5.1280	2026-10-20 06:32:56	192.168.12.100	41546	192.168.12.5	80	6	ET POLICY curl User-Agent ...
RT	2	seconion-...	5.1320	2026-10-20 06:39:28	192.168.12.100	41236	192.168.12.5	5901	6	ET SCAN Potential VNC Sca...
RT	2	seconion-...	5.1322	2026-10-20 06:39:30	192.168.12.100	41236	192.168.12.5	5802	6	ET SCAN Potential VNC Sca...
RT	2	seconion-...	5.1323	2026-10-20 06:39:32	192.168.12.100	41236	192.168.12.5	1433	6	ET SCAN Suspicious inboun...
RT	2	seconion-...	5.1330	2026-10-20 06:40:06	192.168.12.100	41236	192.168.12.5	4333	6	ET SCAN Suspicious inboun...
RT	2	seconion-...	5.1334	2026-10-20 06:40:14	192.168.12.100	41236	192.168.12.5	5432	6	ET SCAN Suspicious inboun...
RT	2	seconion-...	5.1341	2026-10-20 06:40:36	192.168.12.100	41236	192.168.12.5	1521	6	ET SCAN Suspicious inboun...
RT	25	seconion-...	5.1376	2026-10-20 07:33:41						LOCAL-TEST-ICMP
RT	980	seconion-...	5.1378	2026-10-20 08:06:20	192.168.12.100		192.168.12.5		1	LOCAL-TEST-ICMP

Alert yang tercatat

cURL User-Agent pada HTTP port 80.
Indikasi pemindaian layanan.
Paket ICMP (LOCAL-TEST-ICMP).

Cakupan deteksi

Alert memuat waktu, alamat IP, dan layanan.

Deteksi spesifik MQTT dan replay belum terverifikasi.

Sumber: tangkapan layar Sguil dan catatan Purple Team

Empat skenario pengujian keamanan

Sumber 192.168.12.100 | Target 192.168.12.5 | Hanya lingkungan lab

Skenario / kategori	Alat	Target layanan	Hasil yang diperiksa
RT-01 Pemetaan Catatan uji tersedia	Nmap; cURL	TCP 22, 80, 1883, 9000	Port dan versi layanan; pembatasan akses langsung ke API internal.
RT-02 Akses SSH Catatan uji tersedia	ssh_try.py; OpenSSH	SSH :22 root / sec_admin	Penolakan login root/sandi serta pembatasan koneksi berlebih.
RT-03 Web / IoT Verifikasi sebagian	cURL; mqtt_pub.py	REST :80; MQTT :1883 Topik control	Penolakan input tidak valid dan pembatasan hak tulis akun sensor.
RT-04 Replay IoT Rencana	Wireshark; mqtt_pub.py	MQTT :1883 Topik control	Respons terhadap pengulangan payload sah dan perubahan status kendali.

Topik control: cow-sprinkler-01/control. Penolakan autentikasi bukan bukti perlindungan anti-replay.

Sumber: rencana serangan, catatan uji, dan batas pembuktiannya

Prioritas sebelum pengujian lanjutan

C1, C3, dan pengujian replay menjadi prioritas verifikasi berikutnya.

Lab tanpa internet

Python/JSON digunakan sebagai pengganti terbatas Firebase.

Sensor sempat tidak menampilkan alert

IDS dan mode promiscuous diaktifkan; penangkapan paket diperiksa.

Aturan firewall sempat hilang saat reboot

Aturan disimpan dan layanan iptables diaktifkan saat boot.

Tindak lanjut kelompok

1. C1: pengujian ACL MQTT menggunakan akun sensor yang valid.
2. C3: penyamaran token pada log dan verifikasi data hasil pemulihan.
3. RT-04: pengujian pengulangan pesan dan dampaknya pada status kendali.
4. Purple Team: verifikasi ulang kontrol setelah mitigasi.

Target Minggu 11: pengujian keamanan dan verifikasi hasil mitigasi.

Siklus: penyerangan > deteksi > analisis > mitigasi > verifikasi.

Sumber: LOGBOOK dan bukti pengujian